

Curso de Especialización Ciberseguridad en las TIC

Proyecto Server Hardening Linux.

3.1 Auditoría con Lynis

Objetivos

- Evaluar las medidas de seguridad de nuestro servidor Ubuntu con apache2.
- Identificar las vulnerabilidades de nuestro centro educativo.
- Describir las implementaciones para fortalecer el servidor a partir del informe realizado con lynis.
- Comparar la auditoría con y sin las implementaciones para ver la seguridad.

Resumen

Autora: Marina del Pilar López Oliva

Enero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	23/01/2026	Adaptación de la plantilla.
2.0	28/01/2026	Documentación de la práctica.

Índice de Contenidos

1. Introducción.....	4
2. Apartado 1.....	4
3. Apartado 2.....	9
4. Apartado 3.....	10
5. Apartado 4.....	14
6. Conclusiones.....	17
7. Webgrafía.....	17

1. Introducción

En esta práctica vamos a realizar acciones de fortificación en un equipo Ubuntu Server. En este documento se realizará una auditoría con Lynis. Identificaremos los problemas y a partir de estos, describiremos qué acciones son necesarias para mitigarlas e implementarlas en el servidor. Implementaremos los conocimientos adquiridos en el curso e incluiremos consultas de documentación, es decir, implementaciones que puedes realizar con conocimientos no adquiridos en unidades de trabajo previas. Por último hay que comprobar que Lynis realice la comprobación de la vulnerabilidad. Una vez comprobado realizaremos una auditoría de nuestro servidor, describiendo los resultados obtenidos.

2. Apartado 1.

En este apartado vamos a analizar los resultados de la auditoría de seguridad inicial realizada al servidor web iescamp-webserver, basado en Ubuntu Server con el servicio Apache2 en funcionamiento. La auditoría se ha ejecutado utilizando la herramienta Lynis versión 3.0.9, mediante el comando correspondiente.

```
admin@iescamp-webserver:~$ sudo lynis audit system --auditor
"Marina" --report-file /home/admin/iescamp-webserver-27012026
-Audit-Ini.dat
[sudo] password for admin:

[ Lynis 3.0.9 ]

#####
#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free softw
are, and you are
welcome to redistribute it under the terms of the GNU Gener
al Public License.
See the LICENSE file for details about using this software.

2007-2021, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interfac
e and tools)
#####
#####

[+] Initializing program
-----
- Detecting OS ...
[ DONE ]
- Checking profiles ...
[ DONE ]
- Detecting language and localization
[ es ]

-----
Program version:      3.0.9
Operating system:     Linux
Operating system name: Ubuntu
Operating system version: 24.04
Kernel version:      6.8.0
Hardware platform:    x86_64
Hostname:             iescamp-webserver
```

Figura 1. Ejecución de la auditoría mediante Lynis en iescamp-webserver

Esta evaluación es fundamental para establecer una línea base de seguridad, permitiendo identificar vulnerabilidades, configuraciones incorrectas y áreas de mejora en el sistema antes de aplicar medidas de fortificación. Se puede ver toda la salida [aquí](#).

A continuación, se muestran los resultados generales obtenidos tras el escaneo de seguridad.

```
Lynis security scan details:

Hardening index : 58 [#####          ]
Tests performed : 261
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status  [?]
- Security audit      [V]
- Vulnerability scan  [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                 : /home/admin/iescamp-webserver-27012026-Audit-Ini.dat
```

Figura 2. Resultados generales del escaneo de seguridad con Lynis

El servidor presenta un Hardening Index de 58 sobre 100, lo que indica un nivel de seguridad medio-bajo. Durante la auditoría se han ejecutado 261 pruebas de seguridad, detectando múltiples aspectos que afectan a la postura de seguridad del sistema. Asimismo, se observa la ausencia de un escáner de malware instalado, lo que limita la detección de amenazas a nivel de sistema.

Durante el análisis se han identificado dos advertencias críticas (Warnings).

```
Warnings (2):

! Found one or more vulnerable packages. [PKGS-7392]
  https://cisofy.com/lynis/controls/PKGS-7392/

! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/lynis/controls/FIRE-4512/
```

Figura 3. Advertencias críticas detectadas

Análisis detallados de las advertencias:

- Se han identificado uno o varios paquetes con vulnerabilidades de seguridad conocidas. Estos paquetes podrían comprometer la integridad del servidor web completo.
- Se han detectado módulos de iptables cargados en el kernel, pero sin reglas activas configuradas. Esto implica que todos los puertos de red se encuentran accesibles sin restricciones, dejando los servicios expuestos a conexiones externas.

Tras el análisis general, se revisa el estado de seguridad del proceso de arranque y de los servicios del sistema.

```
[+] Arranque y servicios
- Service Manager [ systemd ]
- Checking UEFI boot [ DESHABILITADO ]
- Checking presence GRUB2 [ ENCONTRADO ]
- Checking for password protection [ NINGUNO ]
- Check running services (systemctl) [ HECHO ]
  Result: found 19 running services
- Check enabled services at boot (systemctl) [ HECHO ]
  Result: found 49 enabled services
- Check startup files (permissions) [ OK ]
- Running 'systemd-analyze security'
  - ModemManager.service: [ MEDIO ]
  - apache2.service: [ INSEGURO ]
  - cron.service: [ INSEGURO ]
  - dbus.service: [ INSEGURO ]
  - dm-event.service: [ INSEGURO ]
  - dmesg.service: [ INSEGURO ]
  - emergency.service: [ INSEGURO ]
  - fwupd.service: [ EXPUESTO ]
  - getty@tty1.service: [ INSEGURO ]
  - iscsid.service: [ INSEGURO ]
  - lvm2-lvmpolld.service: [ INSEGURO ]
  - lynis.service: [ INSEGURO ]
  - multipathd.service: [ INSEGURO ]
  - networkd-dispatcher.service: [ INSEGURO ]
  - open-vm-tools.service: [ INSEGURO ]
  - plymouth-start.service: [ INSEGURO ]
  - polkit.service: [ PROTEGIDO ]
  - rc-local.service: [ INSEGURO ]
  - rescue.service: [ INSEGURO ]
  - rsyslog.service: [ MEDIO ]
  - snapd.service: [ INSEGURO ]
  - ssh.service: [ INSEGURO ]
  - systemd-ask-password-console.service: [ INSEGURO ]
  - systemd-ask-password-plymouth.service: [ INSEGURO ]
  - systemd-ask-password-wall.service: [ INSEGURO ]
  - systemd-bsod.service: [ INSEGURO ]
```

Figura 4. Estado de seguridad de servicios del sistema

Hallazgos importantes en la seguridad de los servicios:

- Protección de arranque deficiente. Posibilidad de arranque en modo mantenimiento sin autenticación.
 - UEFI Secure Boot deshabilitado.

- GRUB2 presente pero sin protección por contraseña.
- Gestión de servicios problemáticas.
 - 19 servicios en ejecución, algunos innecesarios para el servidor web.
 - 49 servicios habilitados al arranque, lo que produce una carga excesiva de servicios.
 - 21 servicios clasificados como inseguros, incluyendo: apache2, ssh y cron.
- Servicios específicos de preocupación:
 - ModemManager: inseguro, innecesario en el servidor.
 - Servicios de escritorio presentes, indicativos de una instalación no optimizada: innecesarios para un Ubuntu Server sin escritorio.

El análisis de conectividad y paquetes se resume en la siguiente figura.

```
[+] Puertos y paquetes
- Searching package managers
  - Searching dpkg package manager [ ENCONTRADO ]
  - Querying package manager
  - Query unpurged packages [ NINGUNO ]
- Checking security repository in sources.list.d directory [ OK ]
- Checking APT package database [ OK ]
- Checking vulnerable packages
[ PELIGRO ]
- Checking upgradeable packages
[ OMITIDO ]
- Checking package audit tool
[ INSTALADO ]
  Found: apt-get
- Toolkit for automatic upgrades (unattended-upgrade)
[ ENCONTRADO ]

[+] Conectividad
- Checking IPv6 configuration
[ HABILITADO ]
  Configuration method
[ AUTO ]
  IPv6 only
[ NO ]
- Checking configured nameservers
  - Testing nameservers
    Nameserver: 127.0.0.53
[ OK ]
  - DNSSEC supported (systemd-resolved)
[ DESCONOCIDO ]
- Getting listening ports (TCP/UDP)
[ HECHO ]
- Checking promiscuous interfaces
[ OK ]
- Checking status DHCP client
- Checking for ARP monitoring software
[ NO ENCONTRADO ]
- Uncommon network protocols
[ 0 ]
```

Figura 5. Análisis de conectividad y paquetes

Evaluación de puertos, paquetes y conectividad:

- Gestión de paquetes:
 - Gestor de paquete dpkg encontrado y funcional.
 - Paquetes vulnerables en estado de peligro.

- Omitida la verificación de actualizaciones durante el escaneo.
- Herramienta de auditoría encontrada y disponible.
- Actualizaciones automáticas configuradas.
- Configuración de conectividad:
 - IPv6 habilitado con configuración automática.
 - Interfaces sin modo promiscuo activado.
 - Sin protocolos de red poco comunes.
 - Verificación DNS limitada a servidor local.

Lynis también proporciona un conjunto de sugerencias orientadas a mejorar la postura de seguridad del sistema.

```
Suggestions (51):
* This release is more than 4 months old. Check the website or GitHub to see if there is an update available. [LYNIS]
  https://cisofy.com/lynis/controls/LYNIS/
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
  https://cisofy.com/lynis/controls/DEB-0280/
* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
  https://cisofy.com/lynis/controls/DEB-0810/
* Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]
  https://cisofy.com/lynis/controls/DEB-0811/
* Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]
  https://cisofy.com/lynis/controls/DEB-0880/
* Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without password) [BOOT-5122]
  https://cisofy.com/lynis/controls/BOOT-5122/
* Consider hardening system services [BOOT-5264]
  - Details : Run '/usr/bin/systemd-analyze security SERVICE' for each service
  https://cisofy.com/lynis/controls/BOOT-5264/
* If not required, consider explicit disabling of core dump in /etc/security/limits.conf file [KRNL-5820]
  https://cisofy.com/lynis/controls/KRNL-5820/
* Check PAM configuration, add rounds if applicable and expire passwords to encrypt with new values [AUTH-9229]
  https://cisofy.com/lynis/controls/AUTH-9229/
* Configure password hashing rounds in /etc/login.defs [AUTH-9230]
  https://cisofy.com/lynis/controls/AUTH-9230/
* Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc [AUTH-9262]
  https://cisofy.com/lynis/controls/AUTH-9262/
* When possible set expire dates for all password protected accounts [AUTH-9282]
  https://cisofy.com/lynis/controls/AUTH-9282/
```

Figura 6. Algunas sugerencias de seguridad identificadas por Lynis

El análisis detallado de la auditoría inicial revela que el servidor iescamp-webserver presenta un estado de seguridad preocupante, con múltiples vulnerabilidades críticas y configuraciones por defecto que no resultan adecuadas para un entorno de producción.

Ahora hemos establecido la evaluación inicial del sistema, sirviendo como base para la definición de medidas correctivas y de fortificación que serán tratadas en los siguientes apartados del documento.

3. Apartado 2.

A partir de los resultados obtenidos en la auditoría inicial realizada con la herramienta Lynis, podemos realizar la identificación de las principales vulnerabilidades presentes en el subsistema del servidor web iescamp-webserver.

Este análisis se basa en los hallazgos detectados en la auditoría, permitiendo identificar debilidades en la configuración, en los servicios activos y en los mecanismos de protección que tiene actualmente el sistema.

Las vulnerabilidades críticas que han sido detectadas son las que nos ha avisado anteriormente Lynis mediante los “Warnings”.

- FIRE-4512 - Firewall sin activar. El sistema dispone de módulos iptables cargados en el kernel, pero no existen reglas de filtrado activas. Esto provoca que todos los puertos del servidor sean accesibles sin restricciones. Esto tiene un gran impacto:
 - Exposición completa de servicios como SSH y HTTP.
 - Incremento de la superficie de ataque.
 - Posibilidad de accesos no autorizados desde cualquier origen.
- PKGS-7392 - Paquetes vulnerables detectados. Se han identificado múltiples paquetes con vulnerabilidades conocidas, incluyendo componentes críticos como Apache2 y librerías del sistema. Impacto a nuestra organización:
 - Riesgo de ejecución remota de código.
 - Posible elevación de privilegios.
 - Compromiso del servicio web principal.

A parte, hemos detectado algunas vulnerabilidades más:

- SSH-7408 - Configuración insegura del servicio SSH. El servicio SSH presenta configuraciones por defecto que no cumplen con las recomendaciones de seguridad. Lo que facilita los ataques de fuerza bruta, aumenta el riesgo de accesos no autorizados y posibilita el abuso de túneles SSH.
- BOOT-5122 - Gestor de arranque sin protección. El gestor de arranque GRUB2 no dispone de protección mediante contraseña, permitiendo modificar parámetros de arranque. Esto causa que se pueda acceder al

sistema en modo mantenimiento, que se obtengan privilegios elevados con acceso físico y compromete totalmente al sistema.

- AUTH-9328 - Políticas de permisos débiles. El sistema mantiene valores de umask por defecto, lo que puede permitir que otros usuarios accedan a archivos o directorios no destinados a ellos.
- LOGG-2154 - Logs locales sin protección. Para evitar que se pierdan datos de registros, se recomienda registrar todos los datos en un sistema remoto.

Hay algunas vulnerabilidades más. Este análisis pone de manifiesto que el servidor web del subsistema presenta múltiples vulnerabilidades de distinta gravedad. Destacamos las vulnerabilidades relacionadas con la seguridad de red, la gestión de paquetes y la configuración de servicios críticos.

Se puede obtener la información detallada de las sugerencias. Por ejemplo, accederemos a AUTH-9328. Para poder realizarlas acciones del siguiente apartado, será importante conocer los detalles de las sugerencias que queramos mejorar.

```
admin@iescamp-webserver:~/lynis$ sudo lynis show details AUTH-9328
2026-01-28 15:39:18 Performing test ID AUTH-9328 (Default umask values)
2026-01-28 15:39:18 Test: Checking /etc/profile.d directory
2026-01-28 15:39:18 Result: found /etc/profile.d, with one or more files in it
2026-01-28 15:39:18 Test: Checking /etc/profile
2026-01-28 15:39:18 Result: file /etc/profile exists
2026-01-28 15:39:18 Test: Checking umask value in /etc/profile
2026-01-28 15:39:18 Result: did not find umask in /etc/profile
2026-01-28 15:39:18 Result: found no umask. Please check if this is correct
2026-01-28 15:39:18 Test: Checking umask entries in /etc/passwd (pam_umask)
2026-01-28 15:39:18 Result: file /etc/passwd exists
2026-01-28 15:39:18 Test: Checking umask value in /etc/passwd
2026-01-28 15:39:18 Manual: one or more manual actions are required for further testing of this control/plugin
2026-01-28 15:39:18 Test: Checking /etc/login.defs
2026-01-28 15:39:18 Result: file /etc/login.defs exists
2026-01-28 15:39:18 Test: Checking umask value in /etc/login.defs
2026-01-28 15:39:18 Result: found umask 022, which could be improved
2026-01-28 15:39:18 Suggestion: Default umask in /etc/login.defs could be more strict like 027 [test:AUTH-9328] [details:-] [solution:-]
2026-01-28 15:39:18 Hardening: assigned partial number of hardening points (0 of 2). Currently having 31 points (out of 57)
2026-01-28 15:39:19 Test: Checking /etc/init.d/functions
2026-01-28 15:39:19 Result: file /etc/init.d/functions does not exist
2026-01-28 15:39:19 Test: Checking /etc/init.d/rc
2026-01-28 15:39:19 Result: file /etc/init.d/rc does not exist
2026-01-28 15:39:19 Test: Checking /etc/init.d/rcS
2026-01-28 15:39:19 Result: file /etc/init.d/rcS does not exist
2026-01-28 15:39:19 ===
admin@iescamp-webserver:~/lynis$
```

Figura 7. Detalles de la sugerencia AUTH-9328

Con este apartado hemos identificado y clasificado las vulnerabilidades existentes en nuestro servidor. Esto nos servirá como base para la definición de medidas correctivas y de fortificación que serán abordadas durante el resto del documento.

4. Apartado 3.

A partir del análisis realizado en los anteriores apartados, se proponen las siguientes mejoras con el objetivo de reducir la superficie de ataque y reforzar la seguridad de nuestro servidor Ubuntu Server con apache2 que actúa como servidor de la web del centro.

Lynis nos ha dado 51 sugerencias identificadas en la auditoría inicial, nuestra misión es reducir el número de sugerencias, lo que sería un servidor más seguro.

Vamos a implementar algunas acciones clave para mejorar la seguridad del sistema en función de los resultados.

- FIRE-4512. Las reglas de firewall, o iptables, está cargado pero sin reglas activas. Por lo que hay una exposición total de puertos. “warning[]=FIRE-4512|iptables module(s) loaded, but no rules active”. Se deberían configurar las reglas ufw básico y las políticas por defecto. Con esto, debería desaparecer el aviso de Lynis.

```
admin@iescamp-webserver:~$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
admin@iescamp-webserver:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
admin@iescamp-webserver:~$ sudo ufw allow ssh
Rule added
Rule added (v6)
admin@iescamp-webserver:~$ sudo ufw enable
Firewall is active and enabled on system startup
```

Figura 8. Configuración del firewall por defecto

- PKGS-7392. Hay paquetes vulnerables, incluyendo Apache2 y librerías críticas. “warning[]=PKGS-7392|Found one or more vulnerable packages.” Para solucionar esto, actualizaremos la lista de paquetes disponibles y verificaremos que no queden paquetes vulnerables. Si actualizamos ubuntu con “apt upgrade” deberíamos solucionar el problema.

```
admin@iescamp-webserver:~$ sudo apt upgrade
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Calculando la actualización... Hecho
The following upgrades have been deferred due to phasing:
 libnuma1 numactl
Se actualizarán los siguientes paquetes:
 apparmor bsdextrautils bsdutils cloud-init coreutils dhcpcd-base distro-info-data ejet
 libapparmor1 libblkid1 libdrm-common libdrm2 libfdisk1 libfwupd2 libglib2.0-0 libglib2.0-bin libglib2.0-dev
 libpackagekit-glib2-18 libpam-systemd libsmartcols1 libssl3t64 libsystemd-shared libsystemd-sysv libsystemd0
 netplan-generator netplan.io openssl packagekit packagekit-tools powermgmt-base python3-dbus python3-gi python3-gi-glib
 sosreport systemd systemd-dev systemd-hwe-hwdb systemd-resolved systemd-sysv systemd-timesyncd ubuntu-pro-client-110n
 udev util-linux uuid-runtime
61 actualizados, 0 nuevos se instalarán, 0 para eliminar y 2 no actualizados.
2 standard LTS security updates
Se necesita descargar 605 MB de archivos.
Se utilizarán 11,0 MB de espacio de disco adicional después de esta operación.
```

Figura 9. Actualización del Ubuntu Server

- SSH-7408. Las configuraciones, sobre todo de ssh, por defecto facilita fuerza bruta y abuso. “suggestion[]=SSH-7408|Consider hardening SSH

configuration". En este caso vamos a realizar una configuración básica en el sshd_config.

```
#  
Port 22445  
PermitRootLogin no  
LoginGraceTime 30  
MaxAuthTries 3  
MaxStartups 3  
#AddressFamily any
```

Figura 10. Configuración básica para ssh

- BOOT-5122. GRUB sin contraseña, acceso a modo mantenimiento sin autenticación. "suggestion[]=BOOT-5122|Set a password on GRUB boot loader to prevent altering boot configuration". Le pondremos una contraseña segura como hicimos en el UT2.

```
cat << EOF  
set superusers="admin"  
password_pbkdf2 admin grub.pbkdf2.sha512.10000.2C89F9921  
EOF
```

Figura 11. Contraseña para el hash

- AUTH-9328. Umask por defecto permite acceso de lectura a otros usuarios. "suggestion[]=AUTH-9328|Default umask in /etc/login.defs could be more strict like 027". Modificaremos en los archivos PAM. Hay que investigar cual es el mejor valor para nuestro caso, aunque Lynis aconseja 027. Para nuestro caso, sí que es interesante ponerlo con 027.

```
admin@iescamp-webserver:~$ umask 027  
admin@iescamp-webserver:~$ umask -S  
u=rwx,g=rX,o=
```

Figura 12. Umask configurado con los permisos necesarios

- LOGG-2154. Logs solo en el servidor. "suggestion[]=LOGG-2154|Enable logging to an external logging host for archiving purposes and additional protection". Evitar la manipulación de los logs y embeber todos en un SIEM externo.

Además de realizar las implementaciones, queremos comprobar si la vulnerabilidad Shellshock (CVE-2014-6271) se comprueba con Lynis.

En primer lugar, vamos a buscar el fichero tests_shells y analizarlo para ver si comprueba la vulnerabilidad Shellshock o no, y cómo lo hace si es que lo hace.

```
admin@iescamp-webserver:~/lynis$ sudo cat include/tests_shells
#!/bin/sh

#####
#
# Lynis
# _____
#
# Copyright (c) Michael Boelen, CISOfy, and many contributors.
#
# Website : https://cisofy.com/
# Blog : https://linux-audit.com/
# GitHub : https://github.com/CISOfy/lynis
#
# Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
# welcome to redistribute it under the terms of the GNU General Public License.
# See LICENSE file for usage of this software.
#
#####
```

Figura 13. Listar los tests shell

Se puede ver el contenido completo de tests_shells [aquí](#).

Si lo analizamos en profundidad, podemos ver que no realiza la comprobación de dicha vulnerabilidad. Si queremos que la compruebe, deberemos añadirla. Se añade [esto](#) al final del fichero. El código es recibido de los contenidos de la unidad correspondiente.

```
GNU nano 7.2 include/tests_shells *
# Test : SHLL-6290
# Description : Check for Shellshock vulnerability
Register --test-no SHLL-6290 --weight H --network NO --category securit>
if [ ${SKIPTTEST} -eq 0 ]; then
    FOUND=0
    x=""
    #Display --indent 2 --text "- Testing for Shellshock vulnerabil>
    LogText "Test: Check if bash is in the list of shells."
    if [ -f /etc/shells ]; then
        LogText "Test: checking for bash shell in /etc/shells"
        FIND=`${EGREP_BINARY} '(/usr)?(/local)?/bin/bash' /etc/s>
    else
        LogText "Test: checking if bash is available via which >
        FIND=`which bash 2> /dev/null | head -1`
    fi

    LogText "Result: command revealed ${FIND} as output"
    if [ ! "${FIND}" = "" ]; then
        if [ -x "${FIND}" -a ! -L "${FIND}" ]; then
            LogText "Result: found ${FIND} as a valid shell"
            CreateTempFile || ExitFatal
            SHELLSHOCK_TMP="${TEMP_FILE}"

            # CVE-2014-6271
```

Figura 14. Test para Shellshock

Este test comprueba que la consola bash existe en el sistema o pueda ejecutarse. Si puede, entonces prueba a ejecutar todas las variantes de la vulnerabilidad mostrando todos los pasos por los que pasa y si es o no vulnerable a cada una de las variantes de la vulnerabilidad. Si no existe o no puede ejecutarse la consola bash termina porque no es vulnerable.

5. Apartado 4

Después de realizar las implementaciones de mejoras en el apartado anterior, hemos realizado una nueva auditoría.

```
admin@iescamp-webserver:~$ sudo lynis audit system --auditor  
"Marina" --report-file /home/admin/iescamp-webserver-280120  
26-Audit-Fin.dat
```

Figura 15. Ejecución de la auditoría final con Lynis

La hemos guardado en un fichero nuevo, que podemos ver [aquí](#).

A continuación, se muestran los resultados generales obtenidos tras el escaneo de seguridad.

```
Lynis security scan details:  
  
Hardening index : 66 [#####] ]  
Tests performed : 261  
Plugins enabled : 1  
  
Components:  
- Firewall [V]  
- Malware scanner [X]  
  
Scan mode:  
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]  
  
Lynis modules:  
- Compliance status [?]  
- Security audit [V]  
- Vulnerability scan [V]
```

Figura 16. Resultados generales del escaneo de seguridad con Lynis

Después de la implementación de las acciones en el apartado anterior, vemos que el servidor presenta un Hardening Index de 66 sobre 100. Hemos aumentado el nivel anterior, pues antes estaba en 58.

Durante el análisis ya no se han detectado los “Warnings” pues los hemos corregido con la actualización de Ubuntu y configurando algunas reglas de firewall.

```
-[ Lynis 3.0.9 Results ]-  
Great, no warnings
```

Figura 17. Ninguna advertencia detectada

Tras el análisis general, se revisa el estado de seguridad del proceso de arranque y de los servicios del sistema.

```
[+] Arranque y servicios  
-----  
- Service Manager  
[ systemd ]  
- Checking UEFI boot  
[ DESHABILITADO ]  
- Checking presence GRUB2  
[ ENCONTRADO ]  
- Checking for password protection  
[ OK ]  
- Check running services (systemctl)  
[ HECHO ]  
  Result: found 18 running services  
- Check enabled services at boot (systemctl)  
[ HECHO ]  
  Result: found 49 enabled services  
- Check startup files (permissions)  
[ OK ]  
- Running 'systemd-analyze security'  
  - ModemManager.service:  
[ MEDIO ]  
  - apache2.service:  
[ INSEGURO ]  
  - cron.service:  
[ INSEGURO ]  
  - dbus.service:  
[ INSEGURO ]  
  - dm-event.service:  
[ INSEGURO ]  
  - dmesg.service:  
[ INSEGURO ]  
  - emergency.service:  
[ INSEGURO ]  
  - getty@tty1.service:  
[ INSEGURO ]  
  - iscsid.service:  
[ INSEGURO ]  
  - lvm2-lvmpolld.service:  
[ INSEGURO ]  
  - lynis.service:
```

Figura 18. Estado de seguridad de servicios del sistema

Siguen habiendo muchos riesgos, sin embargo se ha corregido la contraseña en el GRUB2. Ya no pone “NINGUNO” pues ahora ya se ha configurado y aparece en verde como “ENCONTRADO”.

El análisis de conectividad y paquetes se resume en la siguiente figura.

```
[+] Puertos y paquetes
- Searching package managers
- Searching dpkg package manager
[ ENCONTRADO ]
- Querying package manager
- Query unpurged packages
[ NINGUNO ]
- Checking security repository in sources.list.d director
[ OK ]
- Checking APT package database
[ OK ]
- Checking vulnerable packages
[ OK ]

[WARNING]: Test PKGS-7392 had a long execution: 26.529533
seconds
- Checking upgradeable packages
[ OMITIDO ]
- Checking package audit tool
[ INSTALADO ]
  Found: apt-check
  - Toolkit for automatic upgrades (unattended-upgrade)
[ ENCONTRADO ]

[+] Conectividad
- Checking IPv6 configuration
[ HABILITADO ]
  Configuration method
[ AUTO ]
  IPv6 only
[ NO ]
- Checking configured nameservers
- Testing nameservers
  Nameserver: 127.0.0.53
[ OK ]
- DNSSEC supported (systemd-resolved)
```

Figura 19. Análisis de conectividad y paquetes

La diferencia clave aquí es que, como hemos actualizado el servidor Ubuntu, podemos visualizar que ya nos sale como “OK” la comprobación de paquetes vulnerables en lugar de “PELIGRO” como salía antes.

Aunque podemos ver una advertencia que nos dice que el test tiene una ejecución muy larga.

Lynis también proporciona un conjunto de sugerencias orientadas a mejorar la postura de seguridad del sistema.

```
Suggestions (48):
* This release is more than 4 months old. Check the website or GitHub to see if there is an update available. [LYNIS]
  https://cisofy.com/lynis/controls/LYNIS/
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
  https://cisofy.com/lynis/controls/DEB-0280/
* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
  https://cisofy.com/lynis/controls/DEB-0810/
* Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]
  https://cisofy.com/lynis/controls/DEB-0811/
* Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]
  https://cisofy.com/lynis/controls/DEB-0880/
```

Figura 20. Algunas sugerencias de seguridad identificadas por Lynis

Como podemos visualizar hemos dejado unas cuantas sugerencias. Antes nos mostraba 51 sugerencias para cambiar, ahora nos muestra 48. A continuación mencionaremos que ha mejorado.

Sugerencias que hemos corregido:

- FIRE-4512. Hemos aplicado algunas reglas básicas en el firewall con ufw.
- PKGS-7392. Hemos actualizado los paquetes de Ubuntu Server para comprobar que no hubiera ninguno vulnerable.
- BOOT-5122. Le hemos puesto una contraseña al root.
- SSH-7408. Aunque no se ha corregido del todo, hemos mejorado algunos parámetros de la sugerencia con la configuración básica.
- AUTH-9328. Hemos configurado umask a 027 para mejorar la seguridad.

Se demuestra que la aplicación de medidas básicas de hardening tiene un impacto directo y medible en la seguridad del sistema.

6. Conclusiones

La auditoría con Lynis nos ayuda a visualizar cómo de fortificado está nuestro servidor. Además nos indica algunas sugerencias y advertencias críticas que tiene el servidor para corregir.

Es una herramienta muy útil para la fortificación del servidor. Nos puede ayudar a hacernos una idea de que fortificar y como. Además, nos da un código, como "FIRE-4512" para que podamos buscarlo por internet y nos dé alguna idea de cómo mejorarlo.

Con las implementaciones hemos podido ver que nuestro Hardening del servidor ha mejorado significativamente.

7. Webgrafía

Contenidos del 1.5 de la UT4.

[\[Configuración del firewall básico con ufw\]](#)

[\[Configurar seguridad para ssh\]](#)

[\[Configurar umask\]](#)

[[Bastionado de sistema Linux, INCIBE](#)]